

Multi-Tenant Data Isolation Assessment

One Eighty client dashboard — [dashboard.oneeighty.cz](#)

Assessment type	Authorized horizontal privilege-escalation test (owner-commissioned), read-only
Date	2026-08-03
Test identity	Role client , confined to Dr. Dobias Natural Pet Health (dobias)
Tenants attempted	manami, demo
Method	Live black-box testing of production + white-box review of deployed source

1 Executive summary

Cross-tenant data is not accessible. A client-role account confined to dobias could not, by any tested means, read another tenant's revenue, orders, customers, ad spend, or customer personal data. Isolation is enforced **server-side at a single choke point** and does not depend on the browser, the URL, or any client-side state.

Testing went beyond URL manipulation to include browser DevTools tampering, session-cookie inspection, direct request replay at the data (RSC) layer, IDOR probing, and inspection of the raw payload sent to the browser. All cross-tenant data-access attempts were **blocked**.

Two **low-severity information-disclosure findings** were identified. Neither exposes personal data and neither is a cross-tenant data breach; both concern static application copy that names the other tenant (and an internal file path). They are relevant to **client NDA / confidentiality** rather than to GDPR personal-data obligations, and both have one-line remediations.

Question	Verdict
Can a client read another client's numbers?	No
Can a client read another client's customer PII (emails, order history)?	No
Is the control bypassable via URL / DevTools / cookie / direct request?	No
Any GDPR personal-data exposure across tenants?	None found
Any NDA / confidentiality items?	2 low-severity (tenant name in tooltip copy; internal path)

2 Scope & method

Read-only throughout. No data was created, modified, or deleted; no forms were submitted; no settings or admin functions were exercised. Two complementary lenses were used:

- **Black-box** — signed in as the confined client account and attacked the running production system through the browser.
- **White-box** — reviewed the exact source deployed behind that system to confirm why each attack fails and that no untested code path bypasses the control.

The white-box lens matters for assurance: a black-box "blocked" only proves the pages that were clicked. Reading the enforcement point proves the property holds for every page and request shape.

3 Threat model & attack surface tested

The adversary is an **authenticated, legitimate tenant user** (role client, tenant dobias) attempting to reach another tenant's data — the classic horizontal privilege-escalation / IDOR threat, and the realistic insider case: valid credentials, valid session, trusted to see their own data.

#	Attack vector	What was attempted	Result
1	URL parameter rewrite	?client=manami / ?client=demo on snapshot, orders, paid, customers	Blocked
2	Direct request replay (RSC layer)	Replayed requests with RSC:1 header + spoofed ?client=, carrying the real session cookie, bypassing the UI	Blocked
3	Session cookie / JWT tampering	Attempted to read/inspect the session token client-side	Blocked
4	DevTools DOM / JS state manipulation	Looked for client-side state or hidden fields that gate which tenant's data loads	No surface
5	IDOR on per-record routes	Looked for enumerable routes like /orders/{id} scoped by id rather than tenant	No surface
6	Undocumented data API	Looked for REST/API endpoints returning tenant data by parameter	No surface
7	Payload leakage	Inspected the full HTML + serialized RSC "flight" payload for any other-tenant identifiers or data	Clean

Result detail: vectors 1–3 returned dobias data with the requested id ignored; vectors 4–6 have no exploitable surface; vector 7 found no other-tenant numbers or PII in the bytes sent to the browser (two static-copy exceptions in section 5 are application text, not data).

4 Why the control holds (enforcement architecture)

Single server-side choke point

Every data page turns the requested ?client= value into a tenant via one function, resolveClient (lib/clients.ts). For a client-role session it returns the account's own assigned tenant and ignores the requested id entirely, and it fails closed — it throws rather than defaulting if the account has no assignment. The raw requested id is used only inside this function (to detect and log an attempt); it never reaches a data query.

Identity cannot be forged from the browser

Role and assigned tenant id are read from a signed, encrypted session token (NextAuth JWT) and re-resolved from the Postgres app_users table on every token refresh (lib/auth.ts). Nothing the browser controls — URL, cookie value, DOM, or local storage — can influence them. Revoking a user or changing their tenant takes effect without waiting for the session to expire.

The browser never holds the query

The dashboard renders as React Server Components: database queries execute on the server, and the browser receives only rendered output for the already-resolved tenant. There is no client-side data-fetching layer to tamper with — which is why the DevTools and request-replay vectors fail structurally rather than by a check that could be misconfigured.

No alternate paths

There are no per-record routes (no IDOR surface) and no data API routes. The only cross-tenant-capable screens (Data Health, Admin) are gated by server-side role checks that redirect non-internal users, and every admin mutation re-authorizes server-side because a server action is a callable public endpoint.

Defense in depth

Refused cross-tenant attempts are logged. Customer email addresses are masked (e.g. p****e@sonic.net) even for the entitled tenant. The reporting service account holds read access to the aggregated mart dataset only, not to raw PII datasets.

5 Findings

5.1 Core isolation — PASS (no exposure)

Across all seven vectors, no other tenant's numbers or customer personal data were reachable. Representative evidence:

- ?client=manami on /snapshot kept the parameter in the address bar but rendered dobias revenue \$190,483 (identical to baseline).
- ?client=manami on /orders rendered dobias's 1,277 orders with masked dobias customer emails; no manami (CZK / Czech-market) data appeared.
- Direct RSC replay of /customers?client=manami (UI bypassed, real cookie attached) returned dobias's 11,957 customers; no manami records.
- The serialized payload of a ?client=manami page contains zero manami data values.

5.2 Finding A — Tenant named in static metric copy (NDA / confidentiality) — Low

What: Metric caveat text in lib/metrics.ts hard-codes cross-tenant comparisons. The CM3-margin caveat (line 57) reads "Manami's revenue includes VAT (Shoptet does not split it cleanly), so its CM% is not comparable to Dobias's." It renders via MetricTooltip on client-facing pages (e.g. /snapshot), so a dobias user sees the Manami tenant named plus a configuration fact. Other caveats symmetrically cite figures "on Dobias", which a manami user would see.

Why it matters: This is not personal data and not a numbers-of-record leak, so it carries no GDPR breach-notification implication. It is a client-confidentiality / mutual-NDA concern: it discloses the existence of another client relationship and a minor operational detail to a different client.

Remediation: Genericize the caveat wording (drop the other tenant's name and config detail), or parameterize the copy to reference only the viewing tenant.

5.3 Finding B — Internal file path exposed to client users (hygiene) — Low

What: The disabled currency-conversion toggle's tooltip (components/controls/ControlBar.tsx, line 68) includes "See runbooks/23_fx_rates_refresh.md.", surfacing an internal runbook filename to client users.

Why it matters: Minor internal-implementation disclosure; no data or credential value.

Remediation: Show the operational hint only to internal roles, or drop the file path from the client-visible disabledReason string.

6 Recommendations (prioritized)

1	Scrub cross-tenant references from client-visible copy (Finding A). One-file change in lib/metrics.ts.
2	Remove the internal path from the client-visible tooltip (Finding B). One-line change in ControlBar.tsx.
3	Lock the control in with a regression test asserting resolveClient returns the session's own tenant for a client role regardless of requested id, and throws when unassigned. Converts the guarantee into a build-time invariant.
4	Consider durable audit retention: persist refused cross-tenant events to durable storage with a defined retention period, for evidentiary / NDA purposes.

7 Compliance mapping

7.1 GDPR

- **Art. 32 / Art. 5(1)(f) (security, integrity & confidentiality):** Tenant isolation is the core technical measure preventing one client's customer personal data from being accessible to another. Testing found it effective across all vectors.
- **Art. 25 (data protection by design & default):** Supported by server-side enforcement the browser cannot influence, fail-closed defaulting, email masking even for the entitled tenant, and a reporting service account scoped to aggregated data.
- **Art. 4(12) / Art. 33–34 (breach & notification):** The two findings involve no personal data (a company name, a config fact, an internal filename). They do not constitute a personal-data breach and carry no notification obligation.
- **Standing recommendation:** Maintain a durable authorization-audit trail to evidence the effectiveness and monitoring of the Art. 32 measure over time.

7.2 Client NDA / confidentiality

- **Roster confidentiality:** The tenant switcher and the data sent to the browser contain only the viewing tenant — other clients' names and ids are absent from the payload. Holds, except Finding A.
- **Data confidentiality:** One tenant's commercial figures and customer data are not reachable by another tenant. Holds across all tested vectors.
- **Action:** Resolve Finding A to close the one place where another client's existence and a config detail are disclosed in-product.

8 Conclusion

The dashboard's multi-tenant isolation is **robust and correctly located** — enforced on the server, at a single choke point, from an identity the browser cannot forge, with no client-side data path, no per-record IDOR surface, and no data API to bypass it. Attempts to cross tenants via URL rewriting, direct request replay, cookie / DOM / JS tampering, and payload inspection all failed to yield another tenant's data or customer personal data.

Two low-severity, non-personal-data disclosures in static application copy should be tidied for NDA hygiene, and the isolation guarantee should be pinned with a regression test and a durable audit trail. Subject to those items, cross-tenant data is **not** accessible by URL manipulation or by the other attack vectors tested.

Appendix — evidence index

- Baseline (dobias): Revenue \$190,483 • Orders 1,277 • Customers 11,957 • Paid \$9,526 • USD; switcher lists only Dr. Dobias Natural Pet Health.
- Vector 1 (URL): all of {snapshot, orders, paid, customers} x {manami, demo} rendered dobias; screenshots captured during the session.
- Vector 2 (RSC replay): /orders, /customers, /snapshot ?client=manami and /paid?client=demo returned HTTP 200, dobias data, no other-tenant figures/PII.
- Vector 3 (cookie): document.cookie empty (httpOnly).
- Vector 7 (payload): manami appears 0x as a data value; the only manami/czk string hits are the echoed request parameter, the static "USD to CZK" toggle label, and the caveat copy of Finding A.
- Enforcement source: lib/clients.ts (resolveClient), lib/auth.ts, lib/authz.ts.